M1.870 - Fonaments de ciberseguretat

Repte 1: Riscos, vulnerabilitats i amenaces

1. Context Organitzatiu i Estratègic

AERO-DEFENSE DYNAMICS (ADD) s'ha consolidat durant l'última dècada com un dels centres industrials de referència a nivell nacional al sector aeroespacial i de defensa, destacant no només per la seva excel·lència en enginyeria aeronàutica i sistemes de propulsió de precisió, sinó per la seva agressiva estratègia de transformació digital cap al que es coneix com a "Indústria 4.0". Situada en un complex industrial i d'R+D amb més de 60.000 metres quadrats, la companyia gestiona el disseny, l'assemblatge i el manteniment de flota per a més de 20 programes de defensa nacionals i internacionals, a més d'albergar centres de proves d'alta complexitat.

La missió d'ADD transcendeix la mera fabricació industrial; cerca integrar la simulació avançada i la intel·ligència artificial amb la cadena de muntatge i manteniment diari mitjançant l'ús intensiu de dades i IoT industrial. Tot i que aquest avenç tecnològic suposa un gran avantatge, també ha convertit l'organització en un blanc d'alt valor per al ciberespionatge industrial i les Amenaces Persistents Avançades (APT). Aquestes darreres són infiltracions altament sofisticades dissenyades per evadir les defenses i romandre ocultes en els sistemes de l'empresa durant mesos o anys, per tal de robar propietat intel·lectual de manera silenciosa i de manera continuada. La direcció és plenament conscient que un incident de seguretat, com un atac de ransomware que xifraria els plànols de fabricació o una filtració massiva de secrets de defensa, no solament comportaria sancions milionàries i la inhabilitació per a contractes públics, sinó que podria paralitzar la producció i posar en risc directe la seguretat nacional.

Recentment, ADD ha signat un contracte estratègic amb el Ministeri de Defensa per integrar-se a la xarxa de fabricants del nou "Sistema de Combat Aeri de Nova Generació". Aquest acord exigeix que els sistemes d'informació i de planta d'ADD compleixin rigorosament l'**Esquema Nacional de Seguretat (ENS)** a la seva categoria Alta i la normativa de protecció d'Infraestructures Crítiques, elevant els requisits de conformitat i auditoria a un nivell sense precedents. **La vostra tasca, com a responsables de l'àrea de Ciberseguretat, és modelar el sistema per fer una anàlisi de riscos que serveixi de base per a aquesta certificació i per al pla director de seguretat.**

2. Infraestructura del Sistema d'Informació

Per protegir eficaçment l'entorn, és imprescindible comprendre l'anatomia del sistema d'informació, que és un complex híbrid entre tecnologies de la informació (*Information Technology,* IT) i tecnologies d'operació industrial (*Operational Technology*, OT).

El nucli neuràlgic d'ADD resideix al seu Centre de Processament de Dades (CPD) principal, ubicat al búnquer subterrani de l'edifici de comandament i administració. Aquest recinte, considerat una sala tècnica d'accés altament restringit, actua com a cervell de la institució. A l'interior, files d'armaris racks organitzen meticulosament l'equipament informàtic. La sala té un sistema d'alimentació ininterrompuda (SAI) de gran capacitat, recolzat per generadors elèctrics dièsel d'arrencada automàtica. A més, a causa del nivell de classificació dels projectes, el búnquer té equips de destrucció de suports d'informació certificats militarment per a l'eliminació física segura de discos i documents obsolets.

La connectivitat que dóna servei al complex industrial es basa en una infraestructura de cablatge de fibra òptica troncal blindada que uneix els diferents edificis (Naus d'Assemblatge, Laboratoris d'R+D, Centre de Proves). Aquesta xarxa física suporta una arquitectura lògica segmentada vital per a la ciberseguretat. Hi ha una xarxa local (LAN) principal per al trànsit intern, però aquesta es subdivideix mitjançant l'ús de VLANs per aïllar el trànsit crític: una xarxa exclusiva per a robòtica i robòtica de línia de muntatge (OT), una altra per a la xarxa de videovigilància d'alta definició i una xarxa de gestió fora de banda per als administradors de sistemes. A més a més, per a proveïdors i visites tècniques, s'ofereix una xarxa WiFi segregada que, tot i que permet la navegació per Internet, està totalment aïllada dels entorns de disseny i producció. La sortida a l'exterior es realitza mitjançant una connexió a Internet redundant d'alta disponibilitat, protegida per firewalls de nova generació (NGFW) en alta disponibilitat.

3. Actius Tecnològics i Operatius

Sobre aquesta infraestructura de xarxa operen els dispositius que permeten la feina diària del personal. A les oficines de gestió estratègica i compres, l'equip d'usuari estàndard és l'ordinador de sobretaula amb sistema operatiu Windows 11, on es gestionen comandes i tasques administratives. Aquests ordinadors compten amb un antivirus d'última generació capaç de detectar qualsevol arxiu maliciós a l'equip.

Per a altres llocs de treball la mobilitat és clau a la planta de muntatge i a les pistes de proves; per això, els enginyers de camp i mecànics utilitzen equips portàtils amb Linux i telèfons mòbils amb un sistema operatiu Android fortament securitzat, cosa que els permet consultar plànols 3D i telemetria a peu d'aeronau de forma àgil i protegida.

D'altra banda, la maquinària crítica de la planta de mecanitzat (com els torns de control numèric CNC més antics) opera sobre versions legacy de sistemes operatius com Windows XP o Windows 7 Embedded, representant una bretxa potencial de risc considerable que requereix aïllament.

A l'àmbit de la infraestructura centralitzada, ADD ha optat per una arquitectura de virtualització suportada per un clúster de potents servidors físics sota els sistemes operatius Linux i Windows Server. Aquest entorn allotja un hipervisor VMware sobre el qual corren desenes de màquines virtuals que sustenten tot l'ecosistema de programari: des dels servidors de bases de dades (Oracle i SQL Server) que custodien les mètriques de producció, fins als servidors de fitxers amb plànols CAD i normatives d'aviació, passant pel servidor d'aplicacions que executa el PLM/ERP industrial (*Product Lifecycle Management*). Tot aquest parc tecnològic es complementa amb l'ús d'eines ofimàtiques estàndard per elaborar informes i presentacions del projecte

La seguretat perimetral i el control de la xarxa es gestionen des de dispositius específics de comunicacions, però també s'ha implementat una zona desmilitaritzada (DMZ) per publicar serveis

cap a l'exterior sense comprometre la xarxa interna, com ara el portal segur per a proveïdors de la cadena de subministrament.

4. Gestió de la Informació i Serveis Essencials

El valor real d'AERO-DEFENSE DYNAMICS no resideix en les màquines, sinó en la informació que processen i els serveis que presten. L'actiu primordial són les patents de disseny i els plànols de telemetria. La confidencialitat d'aquestes dades és sagrada. Per accedir-hi, el sistema no es basa en la confiança cega; requereix que cada usuari intern (enginyers, operadors, directius) demostri qui és. El sistema centralitzat verifica la identitat digital de l'empleat comparant la informació introduïda amb l'emmagatzemada a la base de dades d'usuaris. No n'hi ha prou de dir qui ets; el sistema ha de validar aquesta afirmació mitjançant l'ús de contrasenyes que només ha de conèixer l'usuari i que ha de renovar periòdicament segons la política de seguretat. Els usuaris estan identificats de manera única mitjançant una adreça de correu electrònic corporatiu. El correu electrònic s'utilitza com a eina principal de comunicació quotidiana.

Un cop dins del sistema, no tots poden veure-ho tot. Hi ha un mecanisme lògic que consulta una llista de permisos (RBAC) associada a cada perfil professional. Aquest mecanisme decideix si un tècnic de manteniment pot veure la fórmula d'un aliatge confidencial (probablement no) o si un enginyer en cap pot autoritzar una modificació al programari del motor. Aquestes dades que defineixen qui pot fer què són vitals per evitar fuites d'informació interna o espionatge industrial.

La capacitat de resposta tàctica d'ADD exigeix la disponibilitat ininterrompuda (24/7/365) dels serveis informàtics neuràlgics, on la mínima latència o interrupció pot paralitzar la producció militar. En aquest nivell de màxima prioritat, destaca la plataforma de comunicacions asíncrones d'alta seguretat, una canalització crítica responsable de transmetre notificacions de control de qualitat en temps real, alertes de fallades en assaigs de vol i ordres d'enginyeria urgents. La caiguda d'aquest flux de dades entre els comptes corporatius no sols congelaria la cadena de muntatge de defensa, sinó que comprometria la coordinació en missions actives i la seguretat del personal al camp.

Un altre pilar ADD és la capacitat de treballar en remot. Enginyers desplaçats en bases militars o directius en viatges oficials disposen d'un servei que permet establir una connexió segura cap a la xarxa del complex a través d'una VPN amb túnel xifrat. Aquest accés a distància és vital per mantenir la correcta operativa.

La col·laboració amb el Ministeri de Defensa i els socis internacionals implica el moviment constant d'informació. L'organització disposa d'un servei dedicat per a l'intercanvi segur d'arxius pesants (SFTP/FTPS), especialment simulacions de fluïds i models CAD en 3D que, per les seves dimensions enormes, no es poden enviar per correu electrònic. Aquest intercanvi ha de ser ràpid i blindat.

Per mantenir l'ordre en una organització amb milers d'empleats i dispositius IoT, hi ha un servei de directori jeràrquic (Active Directory/LDAP). Aquest servei actua com una guia centralitzada que conté la informació de tots els objectes de la xarxa (usuaris, impressores industrials, llocs de control) i en facilita l'administració.

A més, l'empresa ha de garantir la integritat i el no repudi en els comunicats de verificació de vol i firmes de projectes. Per això, s'ha desplegat una Infraestructura de Clau Pública (PKI) per a la gestió del cicle de vida dels certificats digitals. Aquesta tecnologia és la base per a la signatura

electrònica dels certificats d'aeronavegabilitat, assegurant que un document tècnic no s'ha alterat des de la seva aprovació.

5. Protecció, Resiliència i Recuperació

La robustesa del sistema es posa a prova contínuament. Conscients que els errors ocorren i els ciberatacs existeixen, ADD ha implementat una política estricta de salvaguarda. Tota la informació crítica, des dels dissenys d'enginyeria fins a les bases de dades de producció, es duplica periòdicament. Aquests conjunts de dades duplicades s'emmagatzemen en un servidor de còpia de seguretat específic i, posteriorment, es repliquen de forma asíncrona en un emmagatzematge en xarxa (SAN) ubicat en un búnquer secundari a 50 quilòmetres. Aquesta rèplica utilitza discos virtuals amb tecnologia d'immutabilitat (WORM) per garantir la recuperació davant d'un segrest informàtic per ransomware.

No obstant això, restaurar el sistema no és només qüestió de recuperar els fitxers d'enginyeria. Un sistema industrial complex depèn de milers de paràmetres tècnics: regles de tallafocs perimetral, ajustaments de rendiment de les bases de dades, assignació de ports als switches de planta i configuracions del programari PLM. Aquestes dades de configuració del sistema, si es perdessin o fossin alterades maliciosament, deixarien la cadena de muntatge inoperativa o vulnerable, encara que els plànols estiguessin fora de perill. Per això, la seva protecció i el control de canvis sobre aquests canvis és tan crític com el de la pròpia informació de projectes.

Cada acció que passa al sistema deixa una empremta. Des de l'inici de la sessió d'un operari fins a la modificació d'un codi de control numèric, el sistema genera registres cronològics d'esdeveniments (Logs). Aquesta informació, consolidada en un sistema SIEM, és fonamental per al sistema forense digital. Permet als analistes del SOC (Centre d'Operacions de Seguretat) reconstruir què va passar, qui ho va fer i quan, sent una peça clau per a la traçabilitat de la cadena de subministrament i auditories de defensa.

Finalment, la protecció de les dades en trànsit i repòs es recolza en l'ús de criptografia. Per l'accés segur als portals web (intranet corporativa, portal de proveïdors), s'utilitzen certificats SSL/TLS instal·lats als servidors web, garantint que el trànsit navega xifrat. A més, per al transport físic de material classificat o còpies de seguretat puntuals entre plantes, el personal tècnic utilitza discs durs externs xifrats per maquinari.

L'equip humà que gestiona aquesta complexitat inclou no només els enginyers de planta, sinó un departament d'IT/OT robust. Liderats pel CISO, figuren els administradors de sistemes i xarxes, encarregats que els servidors i infraestructura no fallin, i els desenvolupadors de programari intern. També és freqüent la presència de personal de proveïdors externs i mantenidors de robòtica industrial, els quals s'han de sotmetre a estrictes controls d'accés físic i lògic per no introduir codi maliciós ni vulnerabilitats a la xarxa de producció.

Activitats a realitzar

Per realitzar les activitats d'aquest repte, utilitzeu la plantilla de Google Sheets disponible al següent enllaç:

Anàlisi de riscos UOC

Com que el document és de només lectura, has de crear una còpia a "La meva unitat" de Google Drive per poder treballar-hi. Un cop finalitzat, comparteix-ho amb el teu PDC copiant l'enllaç a "Repte 1. Enunciat i entrega". És imprescindible que la còpia realitzada a la unitat de cada estudiant utilitzi com a nom de l'arxiu el format següent: **Nom_Cognom_Repte1.**

a) **Actius**. Per a cadascuna de les categories, seleccioneu els actius presents al sistema d'informació d'AERO-DEFENSE DYNAMICS. El valor entre parèntesis indica el nombre màxim d'actius que podeu seleccionar de cada categoria.

1. [I] Informació / Dades (5)
2. [S] Serveis (5)
3. [SW] Software - Aplicacions informàtiques (3)
4. [HW] Hardware - Equipament Informàtic (3)
5. [COM] Xarxes de comunicacions (3)
6. [Media] Suport d'informació (2)
7. [Key] Claus criptogràfiques / Secrets (1)
8. [AUX] Equipment auxiliar (3)
9. [L] Instal·lacions (3)
10. [P] Personal (3)

Per aquesta activitat et pots recolzar en el Libro II: Catálogo de Elementos de MAGERIT versió 3.

Registra l'activitat a la fulla ***Catalogo_Activos*** de l'aplicació **Anàlisi de Riscos UOC**.

b) **Justificació d'actius essencials.** Per a cadascun dels actius essencials (informació i serveis) seleccionats a l'activitat a), selecciona el fragment de l'enunciat que justifica la teva decisió.

Registra l'activitat a la fulla ***Justificacion_Activos*** de l'aplicació **Anàlisi de Riscos UOC**.

c) **Categorització del sistema segons l'Esquema Nacional de Seguretat (ENS).** Per als actius essencials (informació i serveis) seleccionats a l'activitat a), valora l'impacte sobre cadascuna de les dimensions que suposaria la materialització d'una amenaça. Un cop realitzada la valoració d'actius, assigneu la categoria al sistema d'informació d'AERO-DEFENSE DYNAMICS que correspongui d'acord amb l'ENS.

Per a aquesta activitat et pots recolzar en CCN-CERT BP/14 Declaración de Aplicabilidad.

Registra l'activitat a la fulla ***Categorizacion_Sistema*** de l'aplicació **Anàlisi de Riscos UOC**.

d) Amenaces. Selecciona les dotze (12) amenaces més rellevants per al sistema d'informació d'AERO-DEFENSE DYNAMICS.

Per aquesta qüestió et pots recolzar en el Libro II: Catálogo de Elementos de MAGERIT versió 3.

Registra l'activitat a la fulla ***Catalogo_Amenazas*** de l'aplicació **Anàlisi de Riscos UOC**.

e) Aplicació Amenaces. Determina sobre quins actius tenen més transcendència les amenaces seleccionades a l'activitat d).

Registra l'activitat a la fulla ***Cruce_Activos_Amenazas*** de l'aplicació **Anàlisi de Riscos UOC**.

f) Anàlisi de Riscos. Per a cada tupla actiu-amenaça resultant de les activitats anteriors, estima la probabilitat que l'amenaça es materialitzi sobre l'actiu i l'impacte que això suposaria.

Registra l'activitat a la fulla ***Analisis_Riesgo*** de l'aplicació **Anàlisi de Riscos UOC**.

g) Mesures de Seguretat. Selecciona deu (10) mesures de seguretat de l'annex II de l'Esquema Nacional de Seguretat (ENS), no esmentades a l'enunciat, l'aplicació de les quals minimitzaria el risc residual que suporta el sistema d'informació d'AERO-DEFENSE DYNAMICS. Per a cada mesura de seguretat, a més de classificar-la, justifica l'elecció (màxim 150 paraules per justificació).

Per aquesta qüestió et pots recolzar en l'annex II del Esquema Nacional de Seguretat (ENS).

Registra l'activitat a la fulla ***Medidas_Seguridad*** de l'aplicació **Anàlisis de Riscos UOC**.

h) **Conclusions**. Redacta les conclusions i les reflexions finals sobre el procés d'anàlisi i gestió de riscos. Entre d'altres, heu d'abordar aspectes com la importància de l'anàlisi de riscos en sistemes d'informació, les seves implicacions, les limitacions de l'eina utilitzada i l'aplicabilitat de la metodologia MAGERIT.

Registra l'activitat al full ***Conclusions*** de l'aplicació **Anàlisi de Riscos UOC**.

Criteris d'avaluació

- En aquesta activitat s'han d'escriure les respostes seguint el format establert a la plantilla de respostes proporcionada juntament amb l'enunciat del repte. A l'apartat de lliurament d'aquest repte hi ha una rúbrica que indica els criteris de correcció d'aquesta activitat.

- Aquest repte és un treball personal i individual, realitzat per l'estudiant per a aquest curs i no s'admetran còpies totals o parcials de continguts. Després de verificar-los, els treballs que siguin considerats còpies seran suspesos i s'informarà a la Direcció dels Estudis perquè prengui les mesures oportunes especificades a la normativa de la UOC sobre plagi i còpies (consulteu-ne la guia docent).

- Per a la resolució de les activitats del repte no es permet utilitzar eines d'intel·ligència artificial. En el pla docent i al web sobre integritat acadèmica i plagi de la UOC trobareu informació sobre què es considera conducta irregular a la avaluació i les conseqüències que podria haver-hi.

- El lliurament del present repte per part de l'estudiant implica que ha llegit i accepta les condicions i que el repte compleix els criteris anteriorment exposats quant a privadesa i autoria.

Formats i dates de lliurament

- El lliurament es farà a l'apartat específic de l'aula, “Repte 1. Enunciat i entrega”, copiant l'enllaç al document de Google Sheet on l'alumne hagi resolt les activitats. És obligatori que el document que presenti cada estudiant utilitzi com a nom de l'arxiu el format següent: **Nom_Cognom_Repte1**

- És responsabilitat de l'alumne garantir que l'enllaç compartit sigui accessible en concloure el termini de lliurament. En cas contrari, la PAC es considerarà no presentada.

- La data límit per fer el lliurament d'aquest repte s'indica a l'aula virtual.